

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (Syft 1.46.0 + Grype 0.115.0) · Generated 2026-06-29 · Branch: `fix/depSCAN-20260629-065427`

Summary — Post-Remediation

Metric	Before	After
Total CVEs found	70	10
CRITICAL dependencies	5	0
HIGH dependencies	4	3
MEDIUM dependencies	2	7
Supply-chain alerts	2	0
Typosquatted deps	1	0

Fixes Applied

Dependency	Before	After	CVEs Cleared
org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228 (10.0 CRITICAL), CVE-2021-45046, CVE-2021-45105, CVE-2021-44832
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	CVE-2021-44228 (10.0 CRITICAL), CVE-2021-45046
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.13.4.2	CVE-2020-8840 (9.8 CRITICAL), CVE-2019-14540 (9.8 CRITICAL), CVE-2020-9547, +52 more
com.google.guava:guava	24.1.1-jre	32.0.0-jre	CVE-2020-8908, CVE-2023-2976
commons-io:commons-io	2.4	2.15.1	CVE-2021-29425, CVE-2024-47554
org.apache.commons:commons-lang3	3.4	3.14.0	CVE-2025-48924
mysql:mysql-connector-java	8.0.30	8.0.33	CVE-2023-22102 (8.3 HIGH)
com.fastxml.jackson.core:jackson-databind	2.9.8	REMOVED	TYPOSQUATTED (supply-chain)
http://insecure-mirror.example.net/maven2	present	REMOVED	Untrusted HTTP repo (MITM risk)

Remaining Findings (require MAJOR_REVIEW)

Dependency	Version	Advisory	Severity	Fix Version	Status
mysql:mysql-connector-java	8.0.33	GHSA-m6vm-37g8-gqvH	HIGH	—	GPL-2.0 license + CVE; consider migrating to <code>com.mysql:mysql-connector-j</code>
com.fasterxml.jackson.core:jackson-databind	2.13.4.2	GHSA-j3rv-43j4-c7qm, GHSA-rmj7-2vxq-3g9f	HIGH	2.18.8	Major version jump — MAJOR_REVIEW

org.apache.logging.log4j:log4j-core	2.17.1	GHSA-3pxv-7cmr-fjr4, GHSA-6hg6-v5c8-fphq	MEDIUM	2.25.4	API gap — MAJOR_REVIEW
org.apache.logging.log4j:log4j-core	2.17.1	GHSA-vc5p-v9hr-52mj	MEDIUM	2.25.3	API gap — MAJOR_REVIEW
com.fasterxml.jackson.core:jackson-databind	2.13.4.2	GHSA-3wrr-7qpf-2prh, GHSA-hgj6-7826-r7m5, GHSA-5jnj-h7xm-6q6v	MEDIUM	2.14.0– 2.18.9	Major version jump — MAJOR_REVIEW
org.apache.commons:commons-lang3	3.14.0	GHSA-j288-q9x7-2f5v	MEDIUM	3.18.0	Minor bump available — follow-up

Supply-Chain Alerts — All Cleared

RESOLVED — Typosquatted dependency removed. `com.fastxml.jackson.core:jackson-databind:2.9.8` removed from `pom.xml`.

RESOLVED — Untrusted repository removed. `http://insecure-mirror.example.net/maven2` removed from `pom.xml`.

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 1 + Stage 3.